

## RMF Assessment – SIST Web Infrastructure System

### Assess Task #1

1. Selected Control ID and Name (Copy from RMF4): AU-2: Audit Events

2. What is the objective of this control assessment?

- The objective of this control assessment is to determine if the AU-2 Audit Events control is correctly built and operating within the AWS hosted SIST Web Infrastructure System is the sim of this assessment. It verifies that the security related events including database access, system configuration modifications, user logins, and AWS API activity are recorded and stored.

3. What is the expected timeline of this assessment (i.e., how many hours, days, or weeks will the assessment take?)

The assessment will take approximately 32 hours (4 days).

- Documentation review – 8 hours

- Interviews – 6 hours

- Artifacts examination – 8 hours

- Control testing – 6 hours

- Reporting – 4 hours

4. Identify at least 3 artifacts you would hope to examine from the SIST Web

Infrastructure System to assist with this assessment:

- SIST system security plan
- AWS CloudTrail configuration logs
- Amazon CloudWatch logs configuration
- Amazon S3 audit log storage and retrieving policies
- AWS IAM policies and access management settings

5. Using your answers and the rest of NIST 800-53A, now write an abbreviated assessment plan (3-4 paragraphs) for your control within the SIST Web

Infrastructure System. The plan should include:

The Information System Security Officer (ISSO), Cloud Infrastructure Administrator, and Security Operations Team are among the SIST personnel that will help evaluate the AU-2 control. The system's AWS resources and logging services are maintained by these people.

Three techniques from NIST SP 800-53A will be use for the interview assessment which are: test, interview, and examine. Examining system documentation and AWS configurations, such as CloudTrail logging settings, CloudWatch log collection, and S3 log retention regulations, will be part of the investigate method. This guarantees that the necessary audits events are recorded by the system.

Administrators in charge of setting up AWS logging services will be interviewed. These interviews will validate the methods used to establish logging criteria and monitor logs. In order to confirm that audit events are recorded in CloudTrail or CloudWatch and saved in S3 for investigative purposes, the test technique will entail carrying out controlled actions such as login attempt and IAM modifications.

## Assess Task #2

### FedRAMP Plan of Action and Milestones (POA&M) Template

The FedRAMP POA&M template is the ideal option because the SIST Web Infrastructure System runs in AWS cloud environment. FedRAMP offers a standardized reporting formats designed especially for federal cloud systems. It allows the assessors to record vulnerabilities, risk severity levels, accountable individuals, remediation procedures, and mitigate schedules. This structure allows monitoring security flaws found throughout the assessment and is in good alignment with the RMF procedure outlined in NIST SP 800-37.

## References

National Institute of Standards and Technology. (2018). Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy (SP 800-37 Rev. 2). <https://doi.org/10.6028/NIST.SP.800-37r2>

National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5)<https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2022). Assessing Security and Privacy Controls in Information Systems and Organizations (SP 800-53A Rev. 5). <https://doi.org/10.6028/NIST.SP.800-53Ar5>

National Institute of Standards and Technology. (2006). Guide for Developing Security Plans for Federal Information Systems (SP 800-18). <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-18r1.pdf>

National Institute of Standards and Technology. (2004). Standards for Security Categorization of Federal Information and Information Systems (FIPS 199). <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.199.pdf>

Amazon Web Services. (2024). AWS CloudTrail User Guide. <https://docs.aws.amazon.com/cloudtrail/>

Amazon Web Services. (2024). Amazon CloudWatch User Guide. <https://docs.aws.amazon.com/cloudwatch/>

Amazon Web Services. (2024). Amazon S3 User Guide. <https://docs.aws.amazon.com/s3/>

National Archives and Records Administration. (2024). Controlled Unclassified Information (CUI) Registry. <https://www.archives.gov/cui/registry/category-list>